Desenvolvimento Seguro

B2SEC
cyber protection

Jonathan (Pardal)

jonathan@b2sec.com.br

DevSecOps - Grupo Boticário

AppSec - B2SEC

16+ Dev

9+ InfoSec

Lifestyle Surf e Hacking

linkedin.com/in/jmessias
github.com/jmessiass
t.me/jmessiass

B2SEC

Não basta funcionar, tem que resistir. Código seguro é código que sobrevive ao atacante.

Messias, Jonathan

Desenvolvimento Seguro

01 Caso Real

02 OWASP - Proactive Controls

03 OWASP TOP 10

04 OWASP ASVS

05 OWASP Cheatsheets

06 Segurança com IA

07 DevSecOps

Caso BTG

Caso BTG

Economia

BTG Pactual retoma Pix após ataque hacker que desviou R$ 100 milhões

Banco diz que clientes não foram afetados por invasão

WELLTON MÁXIMO – REPÓRTER DA AGÊNCIA BRASIL
Publicado em 23/03/2026 - 16:00
Brasília

Buscar CBN Economia Entrar

Ataque hacker desvia cerca de R$ 100 milhões do banco BTG Pactual

A falha ocorreu em operações via Pix, no sistema da própria instituição.

Por Rany Veloso — Brasília
23/03/2026 08h21 · Atualizado há 6 dias

Caso Real

Caso Real


```
{
    "cid":"000509c7-c137-4bf4-a760-[redacted]",
    "answers":{
        "cpf":{
            "value":"0708[redacted]",
            "addtional_information":{
                "leaked":true,
                "checkedAt":"2025-12-18T16:15:35.178Z"
            }
        },
        "date-of-birth":{
            "value":"1986-0[redacted]"
        }
    },
    "user_data":{
        "hash":3405883256,
        "width":384,
        "canvas":483341097,
        "height":832,
        "vendor":"Google Inc.",
        "language":"pt-BR",
        "platform":"Linux armv81",
        "timezone":"America/Sao_Paulo",
        "languages":[
            "pt-BR",
            "pt",
            "en-U
            "en"
        ],
        "userAgent
        "Mozilla/5
        amsungBrow
```


Dados PII Sensíveis Expostos

Campo	Exemplo	Classificação
`cpf`	11 dígitos completos	**PII CRÍTICA**
`date-of-birth`	YYYY-MM-DD	**PII SENSÍVEL**
`address`	Endereço completo	**PII SENSÍVEL**
`fingerprint`	Canvas hash	Dados técnicos

VULN-002: 🟣 PII Exposure em Questionários - 6.167 CPFs

Severity: CRÍTICA | **CVSS:** 9.1 | **Milestone:** 2B-KYC-PII-Exposure / 2B-Questionaries-Exposure

Resumo Executivo

Falha crítica que expõe dados altamente sensíveis de 6.167+ clientes. As views `cpv_claim_qa`, `cpv_user_kyc` e `cpv_user_kyc_v2` permite acesso não autenticado a **CPFs completos**, datas de nascimento e endereços via anon key.

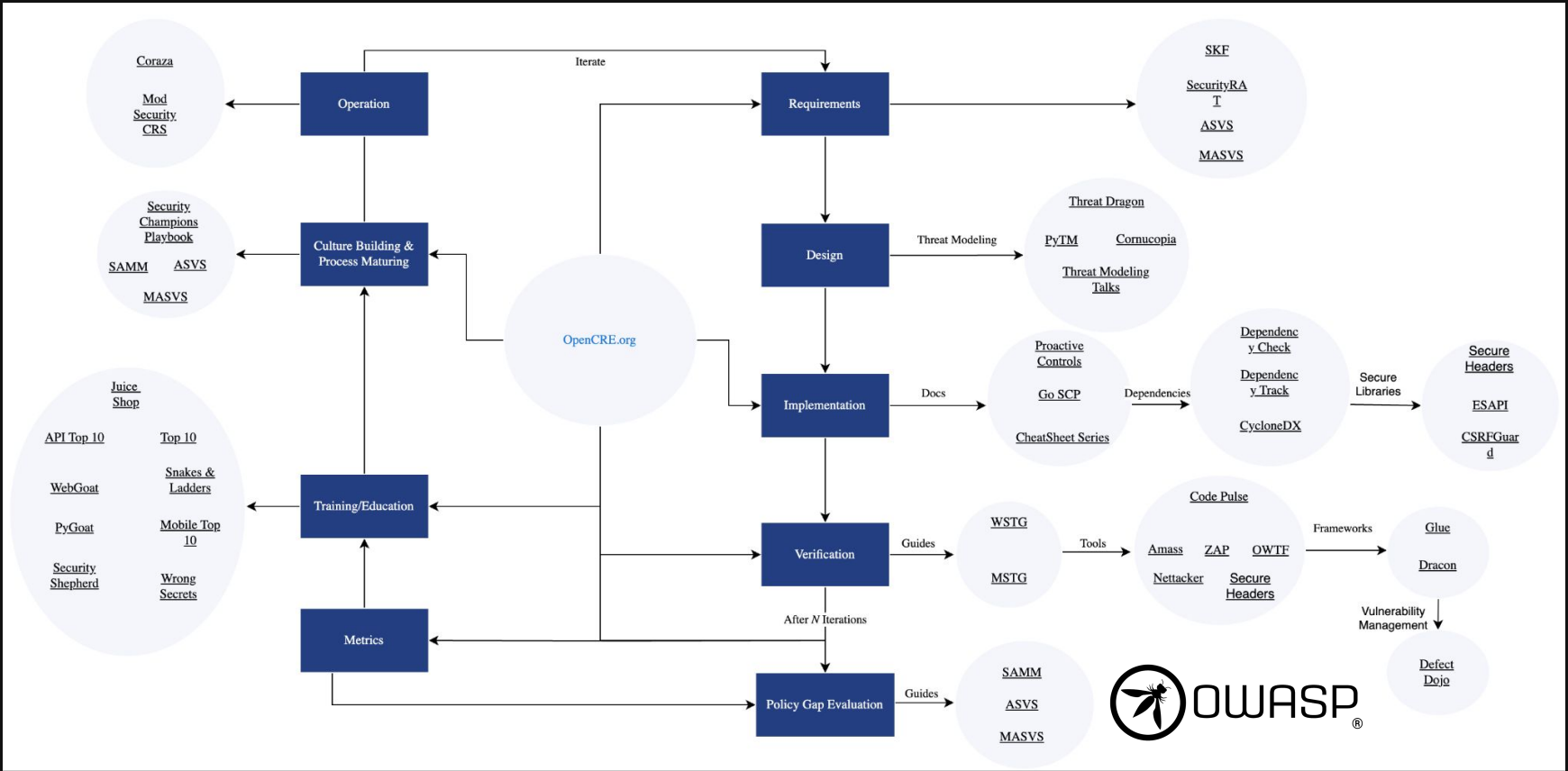
OWASP

- CWE
- OWASP
- OWASP - Top 10
- Proactive Controls
- ASVS
- Cheatsheets
- Vulnerable App

CWE

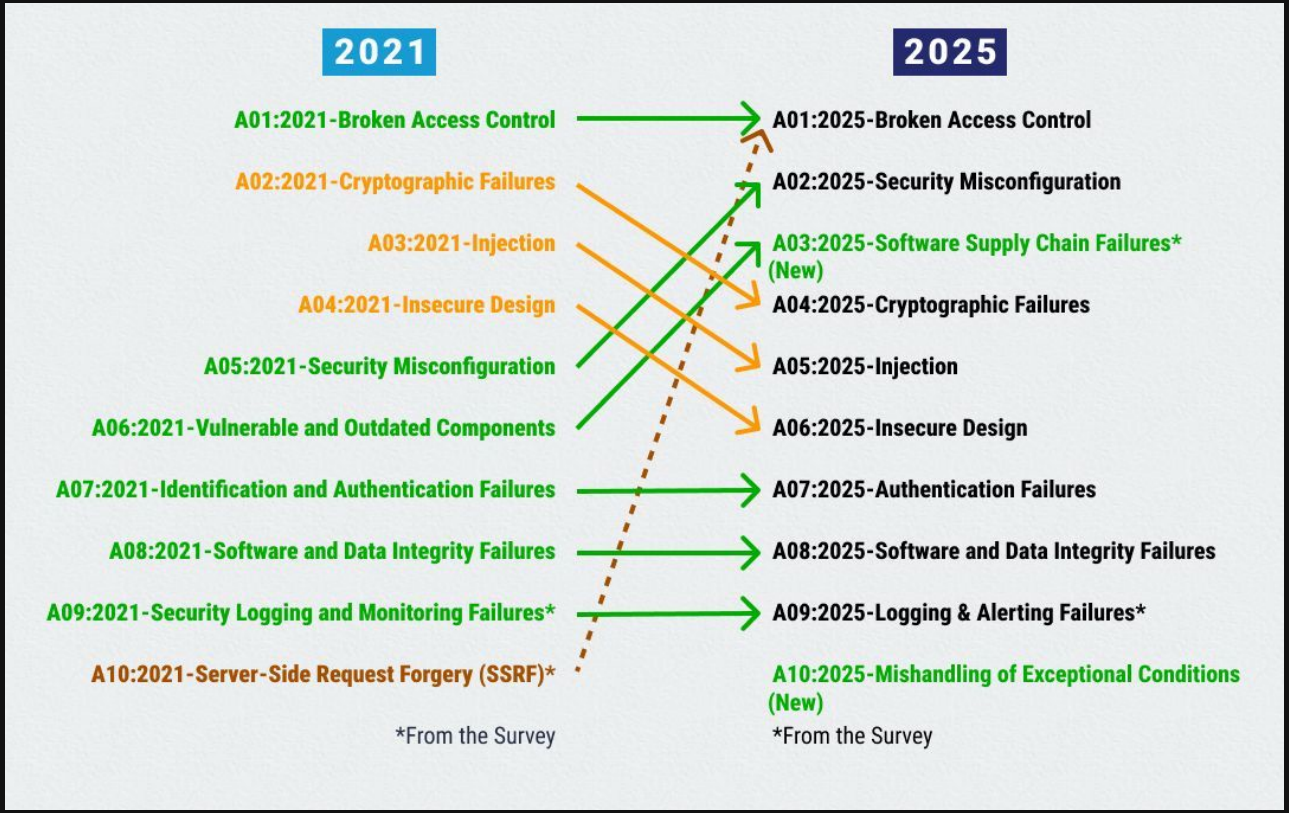
Common Weakness Enumeration é um dicionário comunitário de fraquezas e vulnerabilidades de software e hardware

OWASP


Iterate
Operation
Coraza
Mod Security CRS
Requirements
SKF
SecurityRAT
ASVS
MASVS
Culture Building & Process Maturing
Security Champions Playbook
SAMM
ASVS
MASVS
Design
Threat Modeling
Threat Dragon
PyTM
Cornucopia
Threat Modeling Talks
OpenCRE.org
Implementation
Docs
Proactive Controls
Go SCP
CheatSheet Series
Dependencies
Dependency Check
Dependency Track
CycloneDX
Secure Libraries
Secure Headers
ESAPI
CSRFGuard
Juice Shop
API Top 10
Top 10
WebGoat
Snakes & Ladders
PyGoat
Mobile Top 10
Security Shepherd
Wrong Secrets
Training/Education
Verification
Guides
WSTG
MSTG
Tools
Code Pulse
Amass
ZAP
OWTF
Nettacker
Secure Headers
Frameworks
Glue
Dracon
Vulnerability Management
Defect Dojo
Metrics
After N Iterations
Policy Gap Evaluation
Guides
SAMM
ASVS
MASVS
OWASP®

OWASP - Top 10:2025

OWASP - Top 10


2021
2025
A01:2021-Broken Access Control
A02:2021-Cryptographic Failures
A03:2021-Injection
A04:2021-Insecure Design
A05:2021-Security Misconfiguration
A06:2021-Vulnerable and Outdated Components
A07:2021-Identification and Authentication Failures
A08:2021-Software and Data Integrity Failures
A09:2021-Security Logging and Monitoring Failures*
A10:2021-Server-Side Request Forgery (SSRF)*
*From the Survey
A01:2025-Broken Access Control
A02:2025-Security Misconfiguration
A03:2025-Software Supply Chain Failures* (New)
A04:2025-Cryptographic Failures
A05:2025-Injection
A06:2025-Insecure Design
A07:2025-Authentication Failures
A08:2025-Software and Data Integrity Failures
A09:2025-Logging & Alerting Failures*
A10:2025-Mishandling of Exceptional Conditions (New)
*From the Survey

OWASP - Proactive Controls

OWASP - ASVS

OWASP – Application Security Verification Standard v4.0
The OWASP Application Security Verification Standard (ASVS) Project provides a basis for testing web application technical security controls and also provides developers with a checklist of requirements for secure development.
286 Controls and 14 verification topics
Assurance Level
Level 1
131 Controls
Low assurance level
Level 2
267 Controls
Applications that contain sensitive data
Level 3
286 Controls
Most critical applications
Security Risk

OWASP - ASVS

De fontes em toda a Web

- Access control
- Business logic
- Asvs v1 architecture
- Cryptographic failures
- Malicious code
- Software and data integrity failures
- Error handling and logging
- Configuration
- Asvs v12 files and resources
- Identification and authentication fa...
- Security logging and monitoring fai...
- Vulnerable and outdated compone...
- Session management
- Information privacy
- Asvs v13 api
- Insecure design
- Security misconfiguration

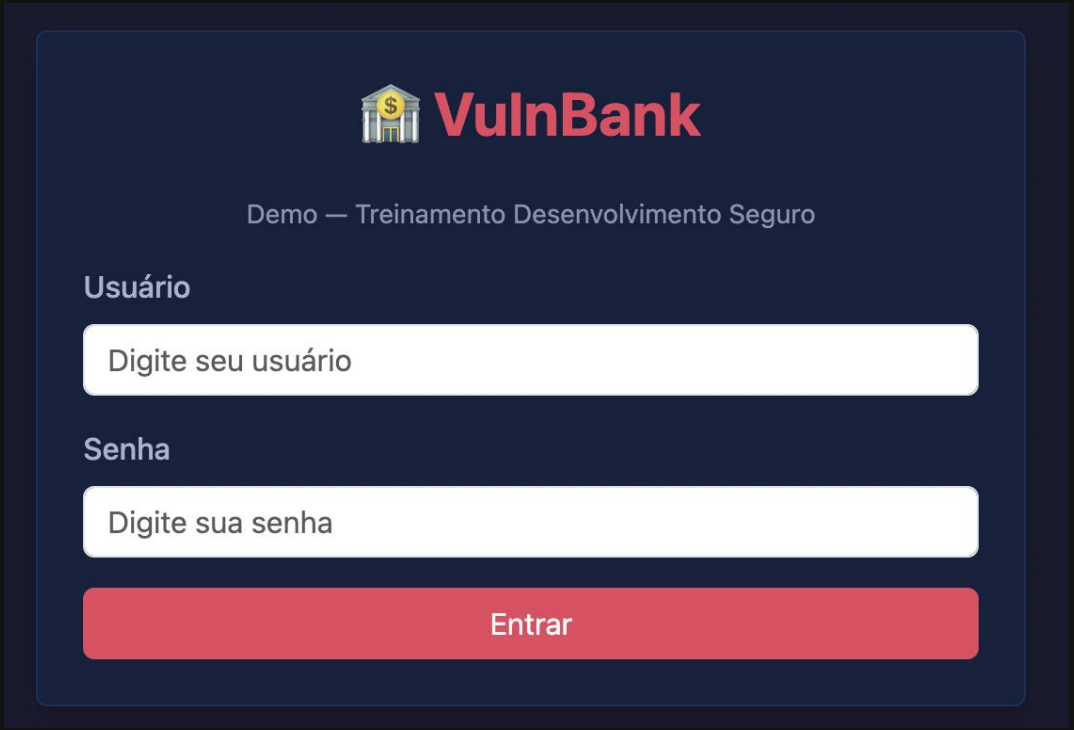
OWASP - ASVS

- V2: Authentication Verification Requirements
  - V2.1 Password Security Requirements
  - V2.2 General Authenticator Requirements
  - V2.3 Authenticator Lifecycle Requirements
  - V2.4 Credential Storage Requirements
  - V2.5 Credential Recovery Requirements
  - V2.6 Look-up Secret Verifier Requirements
  - V2.7 Out of Band Verifier Requirements
  - V2.8 Single or Multi Factor One Time Verifier Requirements
  - V2.9 Cryptographic Software and Devices Verifier Requirements
  - V2.10 Service Authentication Requirements

- V5: Validation, Sanitization and Encoding Verification Requirements
  - V5.1 Input Validation Requirements
  - V5.2 Sanitization and Sandboxing Requirements
  - V5.3 Output encoding and Injection Prevention Requirements
  - V5.4 Memory, String, and Unmanaged Code Requirements
  - V5.5 Deserialization Prevention Requirements

OWASP - Cheatsheets

App Vulnerável



Segurança com IA

Segurança com IA - TOP 10

LLM01: 2025
Prompt Injection

LLM01:2025 Prompt Injection

LLM02: 2025
Sensitive Information Disclosure

LLM02:2025 Sensitive Information Disclosure

LLM03: 2025
Supply Chain

LLM03:2025 Supply Chain

LLM04: 2025
Data and Model Poisoning

LLM04:2025 Data and Model Poisoning

LLM05: 2025
Improper Output Handling

LLM05:2025 Improper Output Handling

LLM06: 2025
Excessive Agency

LLM06:2025 Excessive Agency

LLM07: 2025
System Prompt Leakage

LLM07:2025 System Prompt Leakage

LLM08: 2025
Vector and Embedding Weaknesses

LLM08:2025 Vector and Embedding Weaknesses

LLM09: 2025
Misinformation

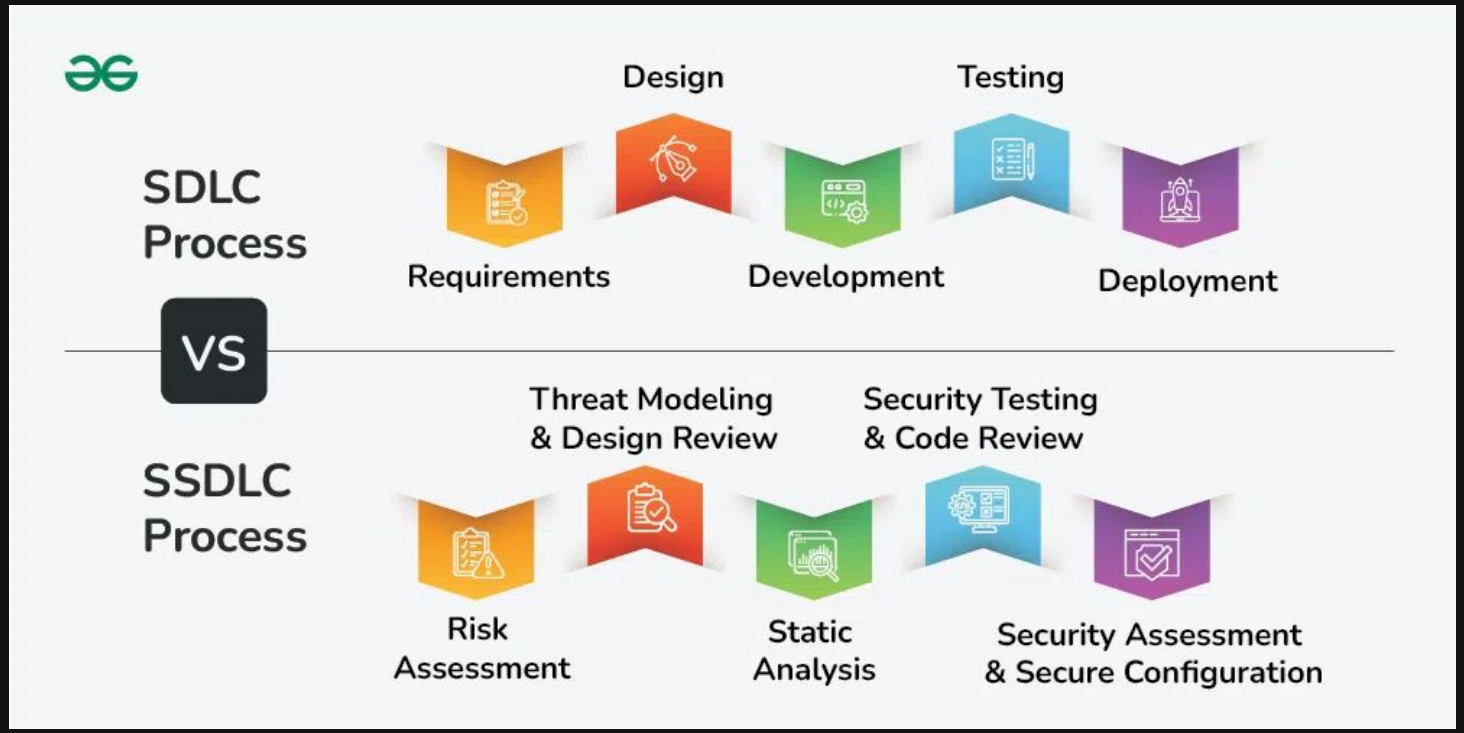
LLM09:2025 Misinformation

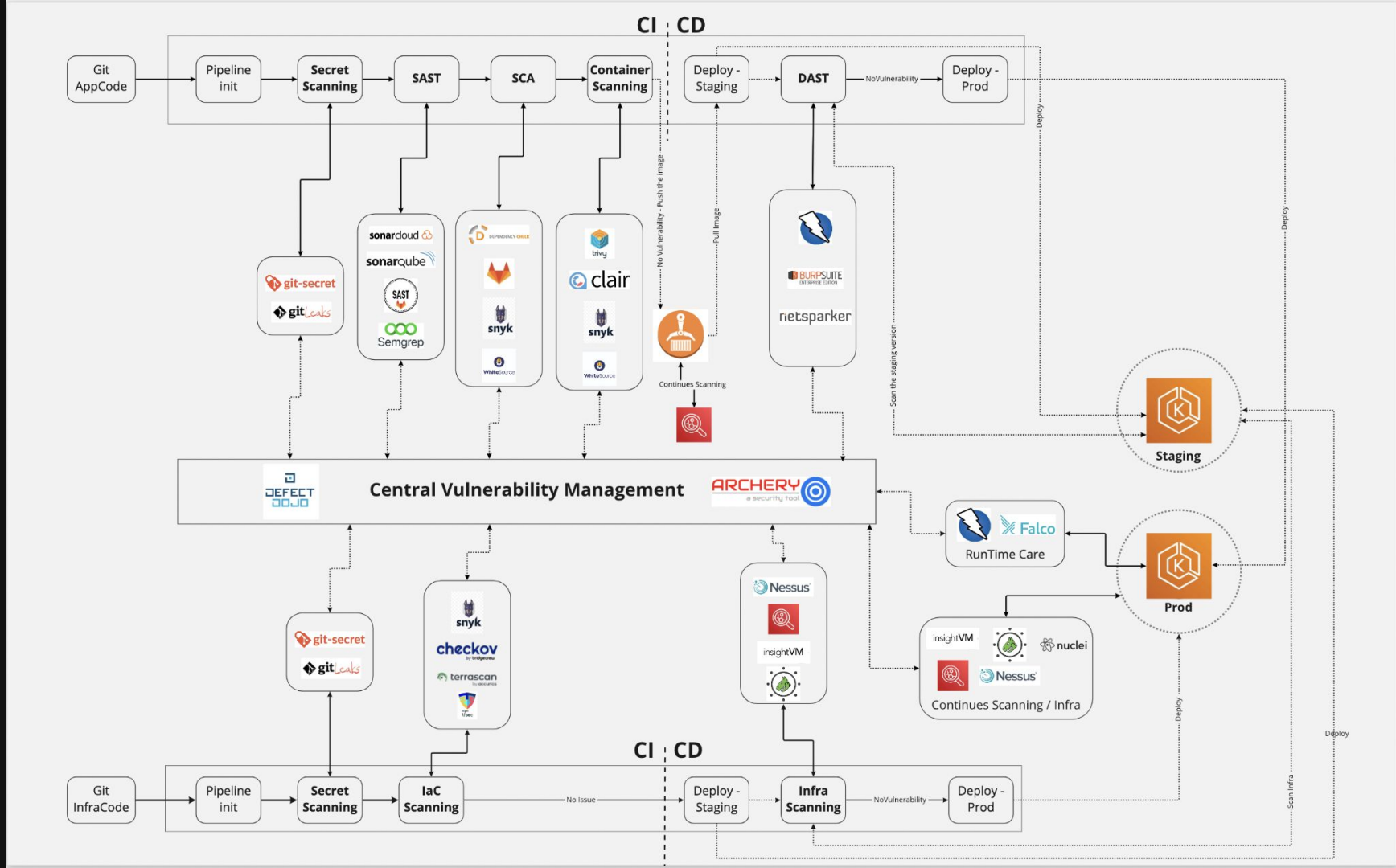
LLM10: 2025
Unbounded Consumption

LLM10:2025 Unbounded Consumption

DevSecOps

SSDLC


SDLC Process
Requirements
Design
Development
Testing
Deployment
VS
SSDLC Process
Risk Assessment
Threat Modeling & Design Review
Static Analysis
Security Testing & Code Review
Security Assessment & Secure Configuration


CI
CD
Git AppCode
Pipeline init
Secret Scanning
SAST
SCA
Container Scanning
Deploy - Staging
DAST
NoVulnerability
Deploy - Prod
Deploy
No Vulnerability - Push the image
Pull Image
Scan the staging version
Deploy
git-secret
gitleaks
sonarcloud
sonarqube
SAST
Semgrep
snyk
WhiteSource
trivy
clair
snyk
WhiteSource
Continues Scanning
BURPSUITE
netsparker
Staging
Central Vulnerability Management
DEFECT DOJO
ARCHERY
Falco
RunTime Care
Prod
Nessus
insightVM
nuclei
Nessus
Continues Scanning / Infra
git-secret
gitleaks
snyk
checkov
terrascan
Nessus
insightVM
Deploy
Deploy
Scan Infra
CI
CD
Git InfraCode
Pipeline init
Secret Scanning
IaC Scanning
No Issue
Deploy - Staging
Infra Scanning
NoVulnerability
Deploy - Prod

Segurança não é feature, é fundação: valide tudo, confie em nada e monitore sempre.

Messias, Jonathan

Referências

https://owasp.org/

https://owasp.org/www-project-top-ten/

https://owasp.org/Top10/2025/

https://owasp.org/www-project-application-security-verification-standard/

https://cheatsheetseries.owasp.org/

https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html

https://cheatsheetseries.owasp.org/cheatsheets/Secure_AI_Model_Ops_Cheat_Sheet.html

https://cheatsheetseries.owasp.org/cheatsheets/LLM_Prompt_Injection_Prevention_Cheat_Sheet.html

https://cheatsheetseries.owasp.org/IndexASVS.html

https://cwe.mitre.org/

https://top10proactive.owasp.org/

https://owasp.org/www-project-devsecops-guideline/

OBRIGADO!!!

B2SEC
cyber protection